TRB Meeting Minutes – August 25, 2026

Document control	
Document ID	MIN-TRBM-2026-08-25
Document type	Meeting Minutes
Date	2026-08-25
Status	Final
Meeting	TRBM-2026-08-25
Review IDs	TRB-2026-002, TRB-2026-007, TRB-2026-008
Feature keys	Attribute-based access control (ABAC)@Platform & Governance; Mode: Databricks-to-Open (bearer/OIDC)@Sharing & Collaboration; Databricks Apps@Apps & Developer Tools
Classification	Internal – Synthetic Sample

> Acme Health Plan is fictional. This is a synthetic sample document for the Databricks Feature Tracker.

Meeting ID: TRBM-2026-08-25
Date: August 25, 2026
Time: 10:00–11:30 AM ET
Quorum: ✓ Yes (8/8 present)

Decisions

1. TRB-2026-002: ABAC (Platform & Governance) – Follow-up

Status: 🔄 **UNDER REVIEW (CONTINUED)**

Rationale: Okta assessment shows controls exist (MFA, admin logging, quarterly reviews), but ABAC hinges on how member-access attributes are governed and kept in sync with IdP. Two open gaps: (1) which system is source of truth for attribute values (Okta, UC, or other)? (2) how to detect/prevent attribute desynchronization (e.g., user promoted but IdP not updated)? These governance questions not yet resolved by design team. Follow-up required.

Next Steps: Enterprise Architect to coordinate with Okta/IAM team and Architecture to answer: (a) governed-tag design and ownership, (b) sync validation mechanism. Re-present at TRBM-2026-09-22 or next available meeting.

Decision Record: None (still Under Review)

---

2. TRB-2026-007: Mode: Databricks-to-Open (Sharing & Collaboration)

Requestor: [Platform Eng Lead]
Databricks Phase: GA
Review Status: Under Review

Presentation Summary: Mode enables Databricks-to-Open sharing: data owners grant external partners (non-Databricks customers) read-only access to shared tables via bearer token or OIDC. Use case: share member claims data with a third-party research organization under a Data Use Agreement (DUA) and BAA.

Board Discussion:
- **CISO:** "How long-lived is the bearer token?" → **Answer:** Token lifetime configurable (default 30 days); bearer token is single-use per query.
- **CPO:** "BAA with the research org—is that signed before sharing begins?" → **Answer:** Yes; Platform team confirms BAA in place before Mode share is provisioned.
- **Compliance Officer:** "Can we audit what external partner queried?" → **Answer:** Yes; Mode logs show recipient IP, query timestamp, rows returned. Logs retained in Databricks audit tables.
- **Enterprise Architect:** "What if recipient shares the token?" → **Answer:** Token is bearer-based; no way to prevent sharing. Mitigation: short lifetime (30 days), IP allowlist if possible, and anomaly detection on query patterns.

Decision: ✓ **APPROVED WITH CONDITIONS**

Condition ID	Requirement	Verification	Owner	Deadline
COND-007-1	BAA signed with external recipient before Mode share provisioned	Legal department confirms BAA on file	Requestor	Per engagement schedule
COND-007-2	Bearer token lifetime ≤30 days; IP allowlist enforced if recipient network known	Spot-check 3 active shares; verify token TTL and IP rules	TRB	2026-10-25
COND-007-3	All Mode query audit logs retained 180 days; TRB conducts	Query audit review; escalate if	Platform Eng	2026-10-25

Condition ID	Requirement	Verification	Owner	Deadline
	monthly anomaly check	>10x normal query volume		

Decision Record: DR-2026-007
PHI-Eligible: ✅ Yes (GA + Conditions)
Conditional Approval Letter: To be issued 2026-08-26

---

3. TRB-2026-008: Databricks Apps – Follow-up

Status: 🔄 **UNDER REVIEW (CONTINUED)**

Rationale: Code review process exists, but two critical questions remain: (1) **User vs. Service-Principal:** Can Databricks Apps run as a service principal (non-human)? If yes, how is service-principal credential rotation handled? (2) **Egress Testing:** How do we prevent an app from exfiltrating query results to an external endpoint? UC controls prevent unauthorized table access, but don't prevent app code from sending results outside. Need to test egress controls (firewall rules, VPC restrictions) with actual app deployment.

Next Steps: Platform Engineering to (a) confirm whether service-principal app execution is required for use case, and if so, design service-principal credential lifecycle; (b) conduct egress test in non-prod workspace. Re-present findings at TRBM-2026-09-22 or next meeting.

Decision Record: None (still Under Review)

Next Meeting

Date: September 8, 2026, 10:00 AM ET

Approved By: [CISO] — Date: August 29, 2026

Classification: Internal – Synthetic Sample